HTTP 네트워크 현황분석과 이상징후 분석

1) **HTTP Log 실습환경 구성**

2) **HTTP 네트워크 현황분석**

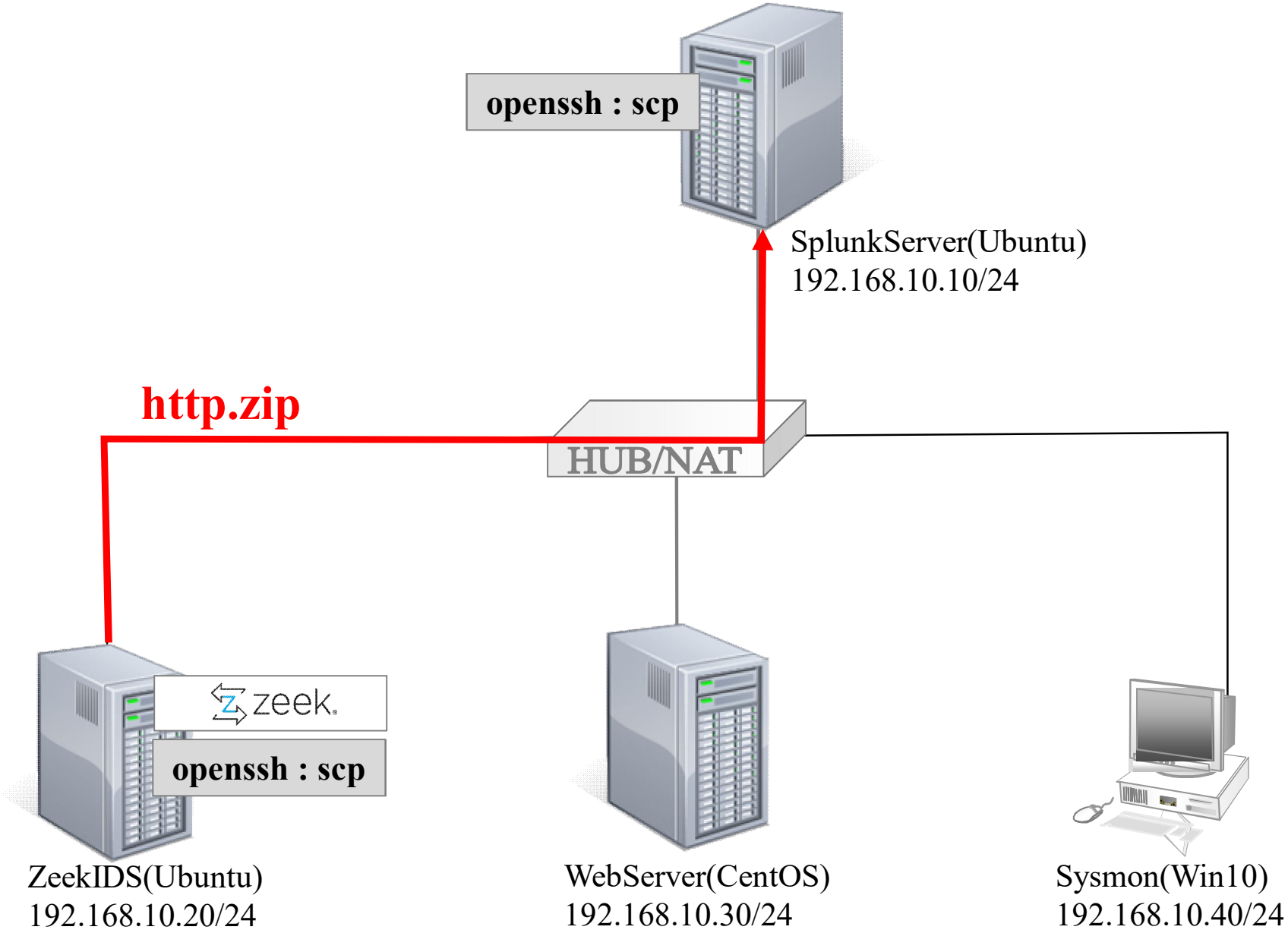
3) **HTTP 이상징후**

1) HTTP Log 실습환경 구성

❶ Index 만들기

❷ SourceType 지정

❸ 데이터 추가


openssh : scp
SplunkServer(Ubuntu)
192.168.10.10/24
http.zip
HUB/NAT
zeek
openssh : scp
ZeekIDS(Ubuntu)
192.168.10.20/24
WebServer(CentOS)
192.168.10.30/24
Sysmon(Win10)
192.168.10.40/24

HTTP 로그 필드

필드명	필드 설명
id.orig_h	송신지IP주소
id.orig_p	송신지 port번호
id.resp_h	수신지IP주소
id.resp_p	수신지 port번호
method	서비스 요청 방식
host	접근 도메인
uri	접근 상세주소 (도메인제외)
referrer	Host 접속시 경유주소
version	HTTP 버전
user-agent	웹브라우저 정보

필드명	필드 설명
request_body_len	서버에게 전송하는 정보길이
response_body_len	사용자에게 전송하는 정보길이
status_code	상태코드
status_msg	상태 메시지
tags	
Proxied	프록시 접속 여부
resp_fuids	연결된 파일 ID
resp_mime_types	전송 파일 mime type

❶ 설정 > 데이터 > 인덱스 > 새로 만들기 인덱스

splunk>enterprise 앱 ▾ Administrator ▾ 메시지 ▾ 설정 ▾ 작업 ▾ 도움말 ▾ 찾기

인덱스

새로 만들기인덱스

Splunk Enterprise 내 데이터에 대한 리포지토리. 인덱스는 인덱서로 알려진 Splunk Enterprise 인스턴스의 플랫 파일에 상주합니다. 자세히 알아보기

12 인덱스 필터 페이지당 20개 ▾

이름	작업	유형	앱	현재 크기	최대 크기	이벤트 수	시작 이벤트	종료 이벤트	홈 경로	동결된 경로	상태
_audit	편집 삭제 비활성화	이벤트	system	18 MB	488.28 GB	173K	15일 전	몇 초 전	$SPLUNK_DB\audit\db	해당 사항 없음	✓ 사용 가능
_configtracker	편집 삭제 비활성화	이벤트	system	4 MB	488.28 GB	272	15일 전	한 시간 전	$SPLUNK_DB_configtracker\db	해당 사항 없음	✓ 사용 가능
_internal	편집 삭제 비활성화	이벤트	system	307 MB	488.28 GB	3.21M	15일 전	몇 초 전	$SPLUNK_DB_internaldb\db	해당 사항 없음	✓ 사용 가능
_introspection	편집 삭제 비활성화	이벤트	system	620 MB	488.28 GB	319K	15일 전	몇 초 전	$SPLUNK_DB_introspection\db	해당 사항 없음	✓ 사용 가능
_metrics	편집 삭제 비활성화	메트릭	system	97 MB	488.28 GB	2.4M	15일 전	몇 초 전	$SPLUNK_DB_metrics\db	해당 사항 없음	✓ 사용 가능
_metrics_rollup	편집 삭제 비활성화	메트릭	system	1 MB	488.28 GB	0			$SPLUNK_DB_metrics_rollup\db	해당 사항 없음	✓ 사용 가능
_telemetry	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	38	15일 전	한 시간 전	$SPLUNK_DB_telemetry\db	해당 사항 없음	✓ 사용 가능
_thefishbucket	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\fishbucket\db	해당 사항 없음	✓ 사용 가능
history	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\historydb\db	해당 사항 없음	✓ 사용 가능
main	편집 삭제 비활성화	이벤트	system	25 MB	488.28 GB	330K	24일 전	11일 전	$SPLUNK_DB\defaultdb\db	해당 사항 없음	✓ 사용 가능
splunklogger	편집 삭제 활성화	이벤트	system	0 B	488.28 GB	0			$SPLUNK_DB\splunklogger\db	해당 사항 없음	사용 불가능
summary	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\summarydb\db	해당 사항 없음	✓ 사용 가능

새 인덱스

×

일반 설정

인덱스 이름 httplog

인덱스 이름(예: INDEX_NAME)을 설정하십시오. index=INDEX_NAME을 사용하여 검색하십시오.

인덱스 데이터 유형 | 이벤트 | 메트릭

저장할 데이터 유형(이벤트 기반 또는 메트릭)

홈 경로 optional

Hot/warm db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/db).

Cold 경로 optional

Cold db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/colddb).

Thawed 경로 optional

Thawed/resurrected db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/thaweddb).

데이터 무결성 검사 | Enable | Disable

Splunk에서 데이터 무결성을 목적으로 데이터의 모든 조각에 대해 해시를 계산하도록 하려면 이 옵션을 활성화합니다.

전체 인덱스의 최대 크기 500 GB

전체 인덱스의 최대 대상 크기입니다.

Hot/Warm/Cold 버킷의 최대 크기 auto GB

버킷의 최대 대상 크기입니다. 높은 볼륨의 인덱스인 경우 'auto_high_volume'을 입력하십시오.

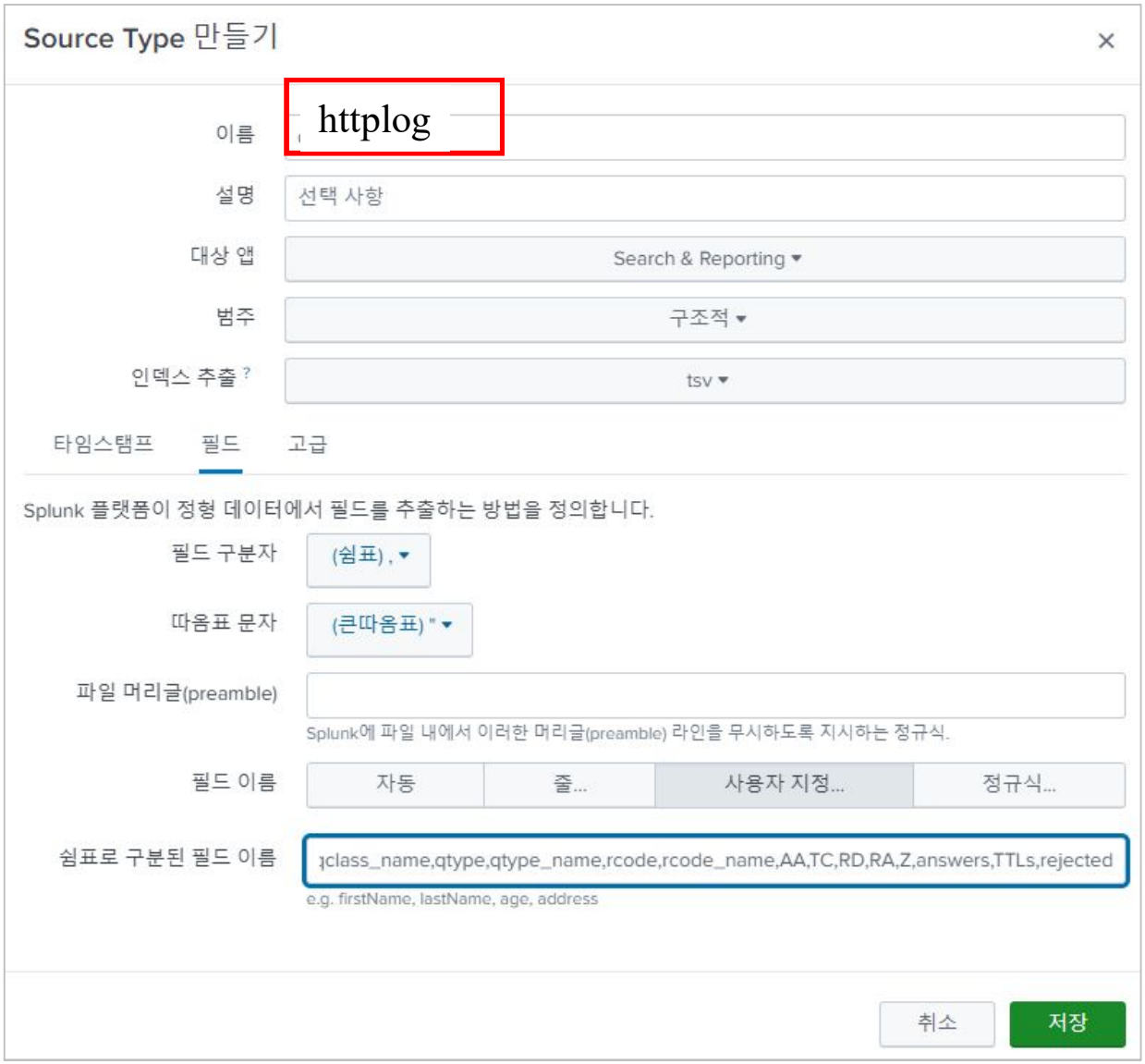
동결된 경로 optional

동결된 버킷 아카이브 경로입니다. Splunk가 동결된 버킷을 자동으로 아카이브하도록 하려면 이 항목을 설정하십시오.

앱 Search & Reporting

저장 취소

❷ 설정 > 데이터 > Source Type > 새로 만들기 Source Type



❸ 데이터 추가

데이터 추가
원본 선택
입력 설정
검토
완료
< 뒤로
다음 >
원본 선택
컴퓨터에서 찾아보거나 파일을 끌어서 아래의 대상 상자에 놓는 방법으로 Splunk 플랫폼에 업로드할 파일을 선택합니다. 자세히 알아보기
미리보기는 이 아카이브 파일에 대해 지원되지 않지만, 인덱싱할 수는 있습니다.
선택한 파일:
http.zip
파일 선택

데이터 추가

원본 선택 · 입력 설정 · 검토 · 완료

< 뒤로 | 검토 >

입력 설정

이 데이터 입력에 대해 다음과 같은 추가 매개 변수를 필요에 따라 설정하십시오.

Source type

source type은 Splunk 플랫폼이 모든 수신 데이터에 할당하는 기본 필드 중 하나입니다. 이를 통해 Splunk 플랫폼은 사용자가 어떤 데이터를 갖고 있는지 알고 인덱싱 중에 데이터 형식을 지능적으로 지정할 수 있습니다. source type은 데이터를 쉽게 검색할 수 있게 분류하는 방법이기도 합니다.

자동 | 선택 | 새로 만들기

httlog

호스트

Splunk 플랫폼이 데이터를 인덱싱할 때 각 이벤트는 "host" 값을 수신합니다. 호스트 값은 이벤트가 발생하는 컴퓨터의 이름이어야 합니다. 사용자가 선택한 입력 유형에 따라 사용 가능한 설정 옵션이 결정됩니다. 자세히 알아보기

- (●) 상수 값
- ( ) 경로에 대한 정규식
- ( ) 경로 내 세그먼트

host 필드 값: **WebServer**

인덱스

Splunk 플랫폼은 수신한 데이터를 선택된 인덱스에 이벤트로 저장합니다. 데이터의 source type을 파악하는 데 문제가 있는 경우 "테스트용" 인덱스를 만들어서 사용할 수 있습니다. 테스트용 인덱스를 사용하면 프로덕션 인덱스에 영향을 주지 않고 설정 문제를 해결할 수 있습니다. 나중에 언제든지 이 설정을 변경할 수 있습니다. 자세히 알아보기

인덱스: **httlog** 새 인덱스 만들기

❶ ~ ❸ Index 만들기

데이터 추가
원본 선택
입력 설정
검토
완료
< 뒤로
제출 >
검토
입력 유형 ..... 업로드된 파일
파일 이름 ..... http.zip
Source Type ..... HTTPlog
호스트 DESKTOP-T79SQGC
인덱스 ..... httplog

2) HTTP 네트워크 현황 분석

- 내부 인트라넷 서비스/ 인터넷 기반 서비스도 대부분 HTTP로 동작
- HTTP를 분석 시 목적지가 인터넷인지 인트라넷 서비스인지 구분 필요
- 공격자가 **내부망에 침투했다면 중요 데이터의 외부유출을 시도함**

  - **따라서 목적지가 인터넷으로 향하는 HTTP인지 아니면 기업 내부망으로 향하는지가 중요한 기준이 될 수 있음**

HTTP 네트워크 현황 분석 항목

❶ Top 10 접속 도메인, 국가별 접속

❷ Top 10 클라이언트 오류

❸ Top 10 서버 오류

❹ HTTP 상태 코드

❺ HTTP 메소드

❶ Top 10 접속 도메인, 국가별 접속

- 사용자들이 가장 많이 접속하는 도메인을 추출해서 접속현황 분석
- 특정 도메인과 국가로 많은 데이터가 전송되거나 낯선 국가명 등을 모니터링
- 접속 국가 정보를 이상징후의 주요 항목으로 사용

iplocation dst	지역 정보를 iplocation 명령어로 검색
where NOT cidrmatch("0.0.0.0/0", domain)	도메인이 IP주소가 아닌 것을 검색함 cidrmatch함수는 IP주소 형식 검사
sum(request_body_len) as "Outbound", sum(response_body_len) as "Inbound	외부행 전송량을 모두 더해 outbound 필드명으로 저장 내부행 전송량을 모두 더해 Inbound 필드명으로 저장
eval Outbound / eval Inbound	Mb 단위로 변환 (소수2자리까지)
sort Outbound desc	Outbound 역순으로 정렬
head 10	총 10개

```
index=httplog sourcetype=httplog domain!="(empty)"
| iplocation dst
| where NOT cidrmatch("0.0.0.0/0", domain)
| stats sum(request_body_len) as "Outbound", sum(response_body_len) as "Inbound"
by domain, Country
| eval Outbound=round(Outbound/(1024*1024),2)
| eval Inbound=round(Inbound/(1024*1024),2)
| sort Outbound desc
| head 10
```

✓ **1,798,194개의 이벤트** (22/07/19 16:56:41.000 이전) 이벤트 샘플링 없음

이벤트 (1,798,194) 패턴 통계 (10) 시각화

페이지당 20개 형식 미리보기

domain	Country	Outbound	Inbound
speedtest.kdatacenter.com	South Korea	31.77	4337.80
go.microsoft.com	United States	1.14	0.01
go.microsoft.com	Malaysia	1.07	0.00
ispt.ahnlab.com	South Korea	0.99	0.02
dmd.metaservices.microsoft.com	United States	0.90	0.00
analytics21.techsmith.com	United States	0.35	0.04
m.adnxs.com	United States	0.33	0.08
mail2.daum.net	South Korea	0.29	2.17
dmd.metaservices.microsoft.com	Hong Kong	0.22	0.00
m.adnxs.com	Singapore	0.22	0.06

❷ HTTP 메소드

- 클라이언트가 서버에 자원을 요청하는 방식
- 클라이언트는 서버에서 Get 또는 Post를 이용해서 자원 요청
- HTTP 표준에서는 많은 메소드를 지원하지만 **사용자가 많이 사용하지 않는 메소드는 공격자의 정보 수집 행위 등 정상적인 사용 범위가 아닐 수 있음**

uri!="-"	Uri 필드 값이 “-”이 아닌 이벤트 검색
top method limit=10 showperc=f	상위 10개의 메소드 검색 각 값이 차지하는 비율 검색하지 않음

```
index=httplog sourcetype=httplog uri!="-"
| top method limit=10 showperc=f
```

✓ **1,570,141개의 이벤트** (22/07/19 17:00:57.000 이전) 이벤트 샘플링 없음

이벤트 (1,570,141) 패턴 통계 (8) 시각화

페이지당 20개 형식 미리보기

method	count
GET	1545746
POST	17461
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
RCON	1
DELETE	1

❸ Top 10 클라이언트 오류

- HTTP의 상태코드는 클라이언트가 요청한 내용을 서버에서 처리한 결과

status_code >=400 AND status_code < 500	Status_Code가 400이상이거나 500미만인 이벤트 검색

```
index=httplog sourcetype=httplog uri!="-" uri!="/"
(status_code >=400 AND status_code < 500)
| top domain, status_code limit=10 showperc=f
```

✓ **3,005개의 이벤트** (22/07/19 17:07:05.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾

이벤트 (3,005) 패턴 **통계 (10)** 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	status_code	count
iopen.kakaocdn.net	404	387
bambooroot.s3.amazonaws.com	404	325
print-screen.us	404	299
2.tlu.dl.delivery.mp.microsoft.com	403	280
thimg.nateon.nate.com	404	216
crl.starfieldtech.com	404	215
7.tlu.dl.delivery.mp.microsoft.com	403	209
11.tlu.dl.delivery.mp.microsoft.com	403	144
www.baidupcs.com	401	109
theme.whale.naver.net	404	80

❹ Top 10 서버 오류

```
index=httplog sourcetype=httplog uri!="-" status_code >= 500
| top domain, status_code limit=10 showperc=f
```

✓ **89개의 이벤트** (22/07/19 17:11:47.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾

이벤트 (89) 패턴 **통계 (10)** 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	status_code	count
images-cf.taboola.com	502	14
crl.globalsign.net	502	11
dmd.metaservices.microsoft.com	503	10
widgetprovider.daum.net	504	8
realdmp.realclick.co.kr	503	8
cafe.daum.net	500	6
sandoll.dl.cdn.cloudn.co.kr	503	5
dh.serving-sys.com	503	5
ocsp.msocsp.com	502	4
c.hotclick.netinsight.co.kr	503	4

❺ HTTP 상태 코드

```
index=httplog sourcetype=httplog domain!="(empty)" status_code!="-"
| top limit=10 showperc=f status_code
```

✓ **1,563,139개의 이벤트** (22/07/19 17:15:59.000 이전) 이벤트 샘플링 없음

이벤트 (1,563,139) 패턴 **통계 (10)** 시각화

페이지당 20개 형식 미리보기

status_code	count
200	1353089
304	107243
204	58260
302	33048
301	3607
404	2366
408	2169
206	1135
403	922
502	381

HTTP 이상징후(P.275)

❶ 비정상 메소드 사용

❷ 외부행 데이터 전송

❸ Mime-type과 파일 확장자 불일치

❹ 사이트 이동 후 실행파일 다운로드

❺ 프록시 서버 접속

❶ 비정상 메소드 사용

- Head, Delete, Trace, Option 과 같은 메소드가 네트워크에서 지속적으로 보인다는 것은 정상적인 사용자의 활동이라 보기 어려움

```
index=httplog sourcetype=httplog
| stats count(method) by src
```

송신지를 기준으로 접속에 사용한 메소드의 종류별 개수 검색

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

❶ 비정상 메소드 사용

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

✓ **1,803,076개의 이벤트** (22/07/19 17:23:14.000 이전) 이벤트 샘플링 없음

이벤트 (1,803,076) 패턴 통계 (2) 시각화

페이지당 20개 형식 미리보기

src	option_count
172.16.132.81	99
172.16.152.196	15

```
index=httplog sourcetype=httplog
| where NOT match(method, "(GET|POST|-)")
| stats count(src) as src_count by method
| sort - src_count
```

✓ **6,934개의 이벤트** (22/07/19 17:44:05.000 이전) 이벤트 샘플링 없음

이벤트 (6,934) 패턴 **통계 (6)** 시각화

페이지당 20개 형식 미리보기

method	src_count
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
DELETE	1
RCON	1

❷ 외부행 데이터 전송

```
index=httplog sourcetype=httplog
(request_body_len!=0 OR response_body_len!="0") domain!="-"
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)
| search oMB!=0 AND iMB!=0 | iplocation dst
| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"
| table src,dst, iMB, oMB, Country, City
```

✓ **556,655개의 이벤트** (22/07/19 17:52:54.000 이전) 이벤트 샘플링 없음 작업

이벤트 (556,655) 패턴 통계 (9) 시각화

페이지당 20개 형식 미리보기

src	dst	iMB	oMB	Country	City
172.16.129.69	103.243.220.234	0.05	0.10	Singapore	Singapore (Downtown Core)
172.16.129.69	103.243.221.108	0.01	0.12	Singapore	Singapore (Downtown Core)
172.16.129.69	104.254.150.108	0.05	0.19	United States	New York
172.16.129.69	104.254.150.179	0.03	0.13	United States	New York
172.16.132.57	203.205.219.196	0.04	0.08	Hong Kong	Hong Kong
172.16.138.2	67.227.186.229	0.02	0.18	United States	Lansing
172.16.138.2	72.52.161.233	0.02	0.18	United States	Lansing
172.16.143.56	203.205.151.204	0.02	0.03	Singapore	Singapore
172.16.156.145	203.205.128.104	0.01	0.02	Hong Kong	Hong Kong

❸ Mime-type과 파일 확장자 불일치

```
index=httplog sourcetype=httplog resp_mime_types="application/x-dosexec" uri!="-“
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| eval filetype=if(match(filename,"(.exe|.bat|.ps1|.dll|.ocx)$"), "PE", "Not_PE")
| table domain, uri, filename, filetype, resp_mime_types
| where filetype=="Not_PE"
| dedup filename
```

✓ **36개의 이벤트** (22/07/19 18:08:45.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾ 상세 모드 ▾

이벤트 (36) 패턴 통계 (1) 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	uri	filename	filetype	resp_mime_types
gms.ahnlab.com	/jk?c=62&p=j69MFyoH3gPJW19ItJuFDXVJ+14Db6DlXR8dTUgUpus=&k=1	jk	Not_PE	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| where cidrmatch("0.0.0.0/0",domain)
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

✓ **1개의 이벤트** (22/07/19 18:52:28.000 이전) 이벤트 샘플링 없음

이벤트 (1) 패턴 통계 (1) 시각화

페이지당 20개 형식 미리보기

src	Target	Source
172.16.154.10	27.101.137.41 :: PelicanC.dll	1

❺ 프록시 서버 접속

```
index=httplog sourcetype=httplog (uri="http://*" OR method="connect")
| table src, domain, uri
```

✓ **6개의 이벤트** (22/07/19 18:57:19.000 이전) 이벤트 샘플링 없음

이벤트 (6) 패턴 통계 (6) 시각화

페이지당 20개 형식 미리보기

src	domain	uri
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/master.idx

3) HTTP 이상징후

❶ 비정상 메소드 사용

❷ 외부행 데이터 전송

❸ Mime-type과 파일 확장자 불일치

❹ 사이트 이동 후 실행파일 다운로드

❺ 프록시 서버 접속

❶ 비정상 메소드 사용

- Head, Delete, Trace, Option 과 같은 메소드가 네트워크에서 지속적으로 보인다는 것은 정상적인 사용자의 활동이라 보기 어려움

```
index=httplog sourcetype=httplog
| stats count(method) by src
```

송신지를 기준으로 접속에 사용한 메소드의 종류별 개수 검색

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

❶ 비정상 메소드 사용

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

✓ **1,803,076개의 이벤트** (22/07/19 17:23:14.000 이전) 이벤트 샘플링 없음

이벤트 (1,803,076) 패턴 통계 (2) 시각화

페이지당 20개 형식 미리보기

src	option_count
172.16.132.81	99
172.16.152.196	15

```
index=httplog sourcetype=httplog
| where NOT match(method, "(GET|POST|-)")
| stats count(src) as src_count by method
| sort - src_count
```

✓ **6,934개의 이벤트** (22/07/19 17:44:05.000 이전) 이벤트 샘플링 없음

이벤트 (6,934) 패턴 **통계 (6)** 시각화

페이지당 20개 형식 미리보기

method	src_count
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
DELETE	1
RCON	1

❷ 외부행 데이터 전송

```
sourcetype=httplog (request_body_len!=0 OR response_body_len!="0") domain!="-"
```

```
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
```

```
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)

| search oMB!=0 AND iMB!=0

| iplocation dst

| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"

| table src,dst, iMB, oMB, Country, City
```

❷ 외부행 데이터 전송

```
index=httplog sourcetype=httplog
(request_body_len!=0 OR response_body_len!="0") domain!="-"
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)
| search oMB!=0 AND iMB!=0 | iplocation dst
| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"
| table src,dst, iMB, oMB, Country, City
```

✓ **556,655개의 이벤트** (22/07/19 17:52:54.000 이전) 이벤트 샘플링 없음 작업

이벤트 (556,655) 패턴 통계 (9) 시각화

페이지당 20개 형식 미리보기

src	dst	iMB	oMB	Country	City
172.16.129.69	103.243.220.234	0.05	0.10	Singapore	Singapore (Downtown Core)
172.16.129.69	103.243.221.108	0.01	0.12	Singapore	Singapore (Downtown Core)
172.16.129.69	104.254.150.108	0.05	0.19	United States	New York
172.16.129.69	104.254.150.179	0.03	0.13	United States	New York
172.16.132.57	203.205.219.196	0.04	0.08	Hong Kong	Hong Kong
172.16.138.2	67.227.186.229	0.02	0.18	United States	Lansing
172.16.138.2	72.52.161.233	0.02	0.18	United States	Lansing
172.16.143.56	203.205.151.204	0.02	0.03	Singapore	Singapore
172.16.156.145	203.205.128.104	0.01	0.02	Hong Kong	Hong Kong

❸ Mime-type과 파일 확장자 불일치

```
index=httplog sourcetype=httplog resp_mime_types="application/x-dosexec" uri!="-“
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| eval filetype=if(match(filename,"(.exe|.bat|.ps1|.dll|.ocx)$"), "PE", "Not_PE")
| table domain, uri, filename, filetype, resp_mime_types
| where filetype=="Not_PE"
| dedup filename
```

✓ **36개의 이벤트** (22/07/19 18:08:45.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾ 상세 모드 ▾

이벤트 (36) 패턴 통계 (1) 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	uri	filename	filetype	resp_mime_types
gms.ahnlab.com	/jk?c=62&p=j69MFyoH3gPJW19ItJuFDXVJ+14Db6DlXR8dTUgUpus=&k=1	jk	Not_PE	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
```

```
Hypertext Transfer Protocol
> [truncated]GET /combiner/c?v=201003241632&css=base.201003241632.css,modules.201003241633.c
  Host: a.espncdn.com\r\n
  User-Agent: Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.9.1.8) Gecko/20100214 Ubuntu/9.10
  Accept: text/css,*/*;q=0.1\r\n
  Accept-Language: en-us,en;q=0.5\r\n
  Accept-Encoding: gzip,deflate\r\n
  Accept-Charset: ISO-8859-1,utf-8;q=0.7,*;q=0.7\r\n
  Keep-Alive: 300\r\n
  Connection: keep-alive\r\n
  Referer: http://espn.go.com/\r\n
  \r\n
```

❹ 사이트 이동 후 실행파일 다운로드

```
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
```

/cgi-bin/PelicanC.dll?impr?pageid=002k&out=iframe

split(uri,"/")

cgi-bin | PelicanC.dll?impr?pageid=002k&out=iframe

filename1=mvindex(split(uri,"/"),-1)

PelicanC.dll | impr | pageid=002k&out=iframe

split(filename1,"?")

filename=mvindex(split(filename1,"?"),0)

❹ 사이트 이동 후 실행파일 다운로드

```
| where cidrmatch("0.0.0.0/0",domain)
```

```
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

File name	Mime type
googletoolbarinstaller....exe	application/x-dosexec
..._chrome_installer.exe	application/x-dosexec
GoogleUpdateSetup.exe	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| where cidrmatch("0.0.0.0/0",domain)
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

✓ **1개의 이벤트** (22/07/19 18:52:28.000 이전) 이벤트 샘플링 없음

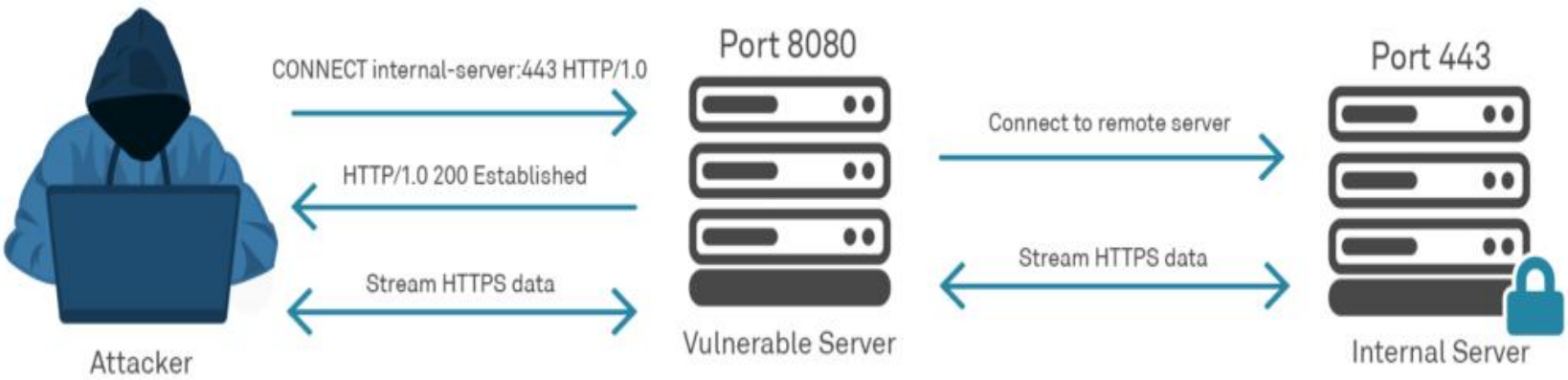
이벤트 (1) 패턴 통계 (1) 시각화

페이지당 20개 형식 미리보기

src	Target	Source
172.16.154.10	27.101.137.41 :: PelicanC.dll	1

Proxy Server

- Connect method : 웹서버에 Proxy 기능을 요청 시 사용




```
> Frame 43: 291 bytes on wire (2328 bits), 291 bytes captured (2328 bits) on interface \Device\NPF_{BD0DBB8D-64FC-47A9-
> Ethernet II, Src: VMware_5f:2c:a1 (00:0c:29:5f:2c:a1), Dst: Fortinet_99:4a:b3 (70:4c:a5:99:4a:b3)
> Internet Protocol Version 4, Src: 194.247.5.7, Dst: 85.25.246.38
> Transmission Control Protocol, Src Port: 57556, Dst Port: 8080, Seq: 1, Ack: 1, Len: 237
v Hypertext Transfer Protocol
  v CONNECT weberblog.net:443 HTTP/1.1\r\n
    > [Expert Info (Chat/Sequence): CONNECT weberblog.net:443 HTTP/1.1\r\n]
      Request Method: CONNECT
      Request URI: weberblog.net:443
      Request Version: HTTP/1.1
    Host: weberblog.net:443\r\n
    Proxy-Connection: keep-alive\r\n
    User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.96 S
    \r\n
    [Full request URI: weberblog.net:443]
    [HTTP request 1/1]
    [Response in frame: 45]
```

HTTPS Connection through a proxy:
method: CONNECT,
while URI lists only the host (without the path)

Proxy Server

- URI에 접속 대상의 전체 주소가 기록 된 경우

  * 클라이언트가 자체적으로 프록시를 설정하고 운영하는 경우

Attacker

uri
http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
http://updates.cdc.carbonblack.io/update/idx/master.idx

❺ 프록시 서버 접속

```
index=httplog sourcetype=httplog (uri="http://*" OR method="connect")
| table src, domain, uri
```

✓ **6개의 이벤트** (22/07/19 18:57:19.000 이전) 이벤트 샘플링 없음

이벤트 (6) 패턴 통계 (6) 시각화

페이지당 20개 형식 미리보기

src	domain	uri
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/master.idx